Universidad Mariano Gálvez de Guatemala
Facultad de Ingeniería en Sistemas de Información
Centro Regional de Mazatenango
Curso: Análisis y Diseño de Sistemas II
Catedrático: Ing. Angel Atilio Maltez C.

Fase de Diseño

Sistema de Gestión del Asilo de Ancianos «Cabeza de Algodón»

Proyecto final · actualizada a la línea base ERS v3.0

Gilmer Iván Ortiz Samayoa
Carné: 3090-23-12685

Mazatenango, Suchitepéquez, 30 de octubre de 2026

Contenido

1. Planificación del trabajo....3
1.1 Metodología....3
1.2 Recursos....3
1.3 Dedicación y capacidad....3
1.4 Plan de iteraciones....3
1.5 Hitos de revisión SQA....4
1.6 Gestión de riesgos....4
2. Arquitectura....6
2.1 Estilo arquitectónico....6
2.2 Vista lógica....6
2.3 Entornos....7
2.4 Nube o servidor propio....7
2.5 Pasos de despliegue....7
2.6 Disponibilidad, rendimiento y respaldos....8
2.7 Seguridad en la arquitectura....8
3. Componentes de software....9
3.1 Vista de componentes....9
3.2 Módulo de acceso y usuarios....10
3.3 Modelo de dominio....11
3.4 Servicios y reglas de negocio....11
4. Experiencia de usuario....13
4.1 Usuarios y contexto de uso....13
4.2 Principios de diseño....13
4.3 Arquitectura de información y navegación....14
4.4 Patrones de interfaz....14
4.5 Estados visibles....15
4.6 Patrones de diseño de software....15
5. Diseño detallado....16
5.1 Especificación de la API....16
5.2 Diseño de seguridad....16
5.3 Diseño de pantallas (wireframes)....17
5.4 Integridad de datos....20

1. Planificación del trabajo

1.1 Metodología

El proyecto lo desarrolla una sola persona, por lo que se eligió un **modelo incremental con iteraciones de dos semanas**. Al final de cada iteración queda una parte del sistema funcionando y revisable, en lugar de probar todo al final. Cada iteración repite cuatro pasos: **requerimiento** (se eligen de la ERS los RF a trabajar), **desarrollo** (código y script SQL), **prueba** (casos de prueba con evidencia) y **revisión SQA**.

Definición de terminado. Un entregable está listo cuando tiene su requerimiento escrito en la ERS, el código y el script SQL al día, su caso de prueba ejecutado con evidencia y una revisión SQA sin hallazgos importantes pendientes.

Control de cambios. Todo cambio de alcance se anota como versión nueva en la tabla de control de versiones de la ERS, indicando qué requerimientos, casos de uso, tablas y pruebas afecta. Lo aprobado entra en la siguiente iteración; lo demás queda para la fase 2.

1.2 Recursos

Recurso	Detalle
Humano	Gilmer Iván Ortiz Samayoa: análisis, diseño, desarrollo, pruebas y documentación. Revisión de calidad: analista SQA del curso.
Equipo	Computadora personal para desarrollo; computadora del asilo o hosting para el despliegue.
Software	XAMPP (Apache, PHP 8, MariaDB, phpMyAdmin) para desarrollo y pruebas; hosting InfinityFree (PHP 8, MySQL, HTTPS) para producción en https://asilo-cabeza-algodon.site.je; navegador Chrome/Edge/Firefox; Python 3 con Playwright; Microsoft Word y Excel; repositorio GitHub I-labGT/sistema-asilo-cabeza-de-algodon.
Información	Necesidades del asilo, informe preliminar SQA (H-01 a H-10) y evaluación por fases SQA (H-11 a H-19).

1.3 Dedicación y capacidad

La disponibilidad es de **15 a 18 horas semanales** durante 13 semanas (24/08/2026 al 20/11/2026), con un total planificado de **230 horas**: 56 de pruebas y 26 de revisión SQA repartidas en todas las iteraciones, y **10 de holgura** (6 en la iteración 6 y 4 en el cierre). La versión 3.1 del plan (01/11/2026) agregó 12 h para corregir los hallazgos de la evaluación SQA por fases sin cambiar el total, tomando horas de tareas terminadas antes de tiempo. El archivo Planificacion_Asilo_Cabeza_de_Algodon_v3.1.xlsx comprueba la suma con una fórmula, registra las horas ejecutadas y su desviación, y trae las hojas Riesgos y Recursos.

1.4 Plan de iteraciones

Iteración	Fechas	Contenido	Horas
I1	24/08 – 04/09	Análisis y línea base	35
I2	07/09 – 18/09	Modelo de datos y prototipo de pantallas	35
I3	21/09 – 02/10	Seguridad, usuarios, residentes y habitaciones	35
I4	05/10 – 16/10	Atención médica: ficha, signos, citas, laboratorio, medicamentos	35

Iteración	Fechas	Contenido	Horas
I5	19/10 – 30/10	Farmacia, facturación, reportes, panel y API MySQL; atención del informe SQA	35
I6	02/11 – 13/11	Despliegue, pruebas de aceptación y cierre de hallazgos	35
Cierre	16/11 – 20/11	Manuales, documentación final y exposición	20
Total	13 semanas		230

1.5 Hitos de revisión SQA

Hito	Fecha	Qué se revisa	Criterio para aprobar
SQA 1	04/09	Alcance y ERS	Cada RF es claro, único y verificable; alcance v1 y fase 2 definidos
SQA 2	18/09	Modelo de datos	El script SQL coincide con el diccionario de datos
SQA 3	02/10	Seguridad y residentes	PV-01 a PV-18 y CP-01 a CP-07 aprobadas
SQA 4	16/10	Atención médica	CP-08 a CP-10 y CP-15 a CP-18 aprobados
SQA 5	30/10	Administración y hallazgos	Respuesta a H-01 a H-10 con evidencia
SQA 6	13/11	Verificación en ejecución	Hallazgos cerrados por el analista SQA
Cierre	20/11	Documentación final	Control de versiones actualizado

1.6 Gestión de riesgos

ID	Riesgo	Prob.	Impacto	Mitigación	Contingencia
R-01	El hosting gratuito se cae o suspende la cuenta	Media	Alto	Monitor de disponibilidad y respaldo semanal	Instalar en XAMPP del asilo con el último respaldo
R-02	Pérdida de datos por falta de respaldo	Media	Alto	Respaldo semanal; restauración probada (PR-07)	Restaurar el último .sql
R-03	El personal no adopta el sistema	Media	Alto	Capacitación por rol y manual con capturas	Acompañamiento la primera semana
R-04	Acceso indebido a datos clínicos	Baja	Alto	HTTPS, PBKDF2, filtro por rol, bloqueo de intentos	Desactivar la cuenta y revisar la bitácora
R-05	El horario de RNF-04 no coincide con el del asilo	Media	Medio	Confirmación escrita con la administración	Ajustar RNF-04 y el monitor
R-06	Retraso por carga académica	Media	Medio	Holgura de 10 h y prioridades por iteración	Pasar funciones no críticas a la fase 2
R-07	Nuevos hallazgos SQA en la revisión final	Media	Medio	Pruebas automatizadas repetibles y registro de defectos	Usar la holgura de cierre
R-08	Límites del plan gratuito (sin vistas ni procedimientos)	Alta	Bajo	El sistema no depende de vistas ni procedimientos	Plan de pago o XAMPP local

El registro completo, con nivel calculado, responsable y estado, está en la hoja «Riesgos» de la planificación v3.1 y se revisa al cierre de cada iteración.

2. Arquitectura

2.1 Estilo arquitectónico

Cliente-servidor en **tres capas** (presentación, lógica de negocio y datos). La comunicación entre la página y el servidor es HTTP con cuerpos JSON hacia un único punto de entrada, api/api.php, que recibe la acción en el parámetro accion.

2.2 Vista lógica

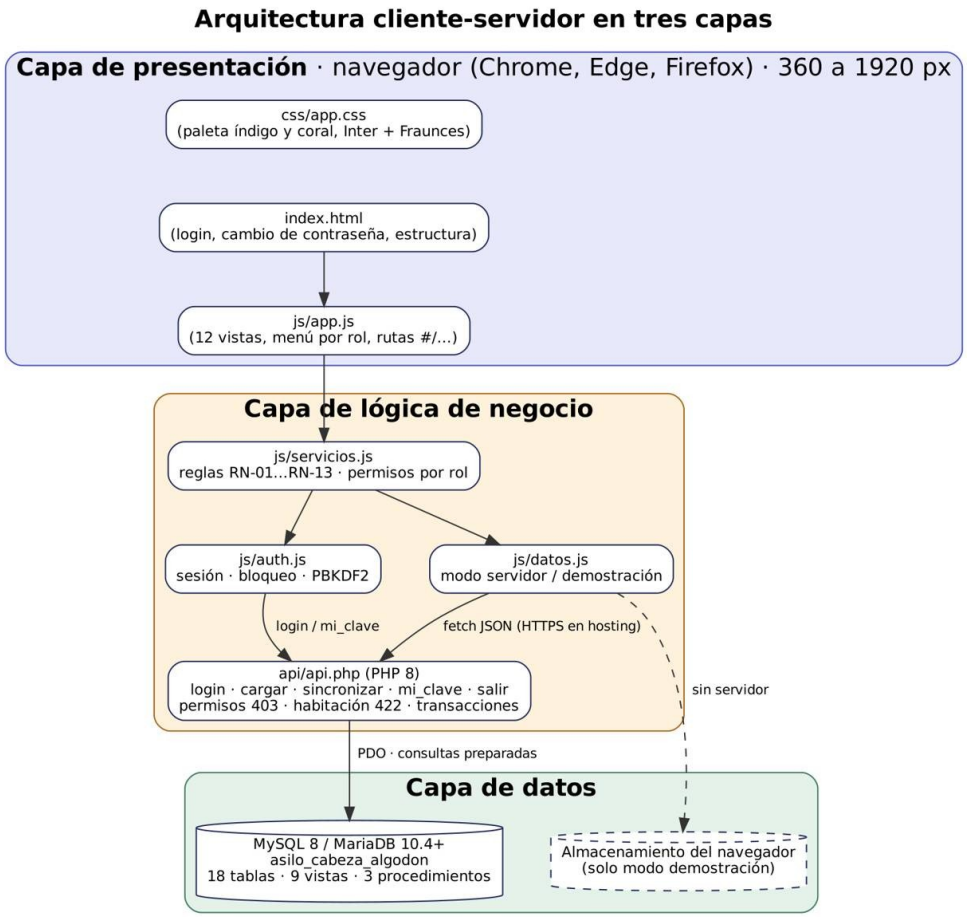


Figura 1. Vista lógica en tres capas

Acción de la API	Qué hace	Quién puede
estado / publico	Indica si hay base de datos disponible	Cualquiera
login	Valida usuario y contraseña con PBKDF2, aplica el bloqueo y abre la sesión	Cualquiera
verificar	Devuelve la sesión actual	Con sesión
mi_clave	Cambia la contraseña propia o la temporal	Con sesión
cargar	Entrega SOLO los datos que corresponden al rol (filtrados en el servidor, H-14) y el siguiente id global de cada tabla	Con sesión y contraseña no temporal

Acción de la API	Qué hace	Quién puede
sincronizar	Guarda altas, cambios y bajas dentro de una transacción; revisa permisos y reglas de servidor	Según la tabla y el rol
vaciar	Restablece los datos iniciales; las cuentas de usuario se conservan	Solo Administrador
salir	Destruye la sesión	Con sesión

2.3 Entornos

Entorno	Uso	Configuración
Demostración	Practicar y presentar sin servidor	Abrir index.html; datos de prueba en el navegador
Desarrollo y pruebas	Programar y ejecutar las pruebas automatizadas	XAMPP local con la base importada desde 01, 02 y 03 .sql
Producción	Uso real del asilo	XAMPP en la red local u hosting con HTTPS (scripts de basedatos/hosting)

2.4 Nube o servidor propio

Se dejan preparadas las dos opciones. El **servidor propio** (XAMPP en una computadora del asilo) no tiene costo mensual y funciona sin Internet dentro de la red local, pero depende de que ese equipo esté encendido y respaldado. El **hosting** da acceso desde cualquier lugar con HTTPS y respaldo del proveedor, a cambio de una mensualidad. La decisión final corresponde a la administración del asilo; la iteración 6 contempla el despliegue y su prueba (RNF-04 y RNF-08).

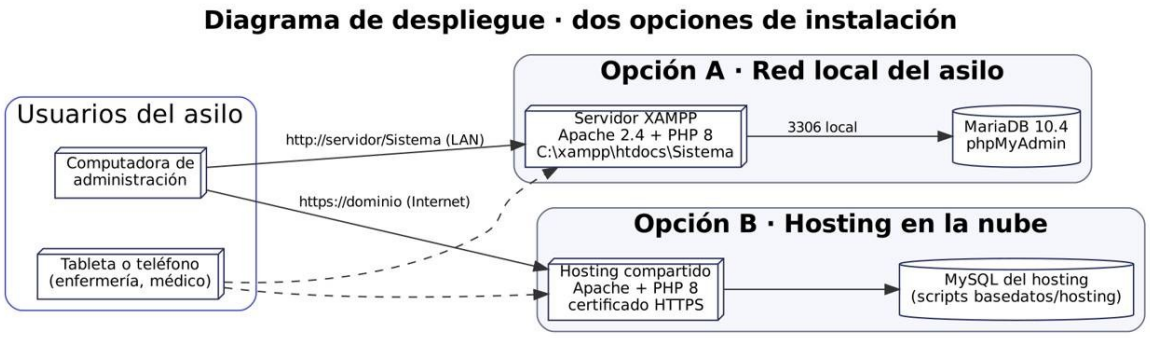


Figura 2. Arquitectura de despliegue

2.5 Pasos de despliegue

1. Copiar la carpeta Sistema en C:\xampp\htdocs (o en public_html del hosting).
2. Importar en phpMyAdmin, en orden, 01_esquema.sql, 02_datos.sql y 03_consultas.sql (en hosting, los archivos de basedatos/hosting, que no crean la base).
3. Revisar los datos de conexión en api/config.php.
4. Abrir http://localhost/Sistema/ (o el dominio con https) y entrar con la contraseña temporal del administrador, que se entrega por separado; el sistema obliga a cambiarla.
5. Crear las cuentas del personal desde Usuarios.

2.6 Disponibilidad, rendimiento y respaldos

- Disponibilidad objetivo: lunes a sábado de 07:00 a 18:00 con 99 % del horario (RNF-04, propuesto).
- Rendimiento: búsquedas y listados en menos de 2 s con hasta 200 residentes (RNF-05); medido 0.03 s con los datos de prueba.
- Respaldos: exportación semanal desde phpMyAdmin y descarga JSON desde el módulo Usuarios (RF-24).

2.7 Seguridad en la arquitectura

- Contraseñas con PBKDF2-SHA256, 600 000 iteraciones y sal de 16 bytes, en formato versionado «pbkdf2_sha256$600000$...»; el hash lo calcula PHP y la página nunca lo recibe (H-18).
- Contraseñas iniciales temporales con cambio obligatorio; mientras tanto el servidor no entrega datos (HTTP 403).
- Bloqueo de 30 s tras 3 intentos fallidos y registro de cada intento con la IP.
- Sesión renovada al entrar (session_regenerate_id) y cierre por inactividad de 30 minutos en la página.
- Mínimo privilegio en el servidor: cada rol recibe solo sus datos y se revisa qué registros modifica (HTTP 403); transacciones en cada guardado (H-14).
- Modo demostración solo si se pide (archivo local o ?demo=1) y con cuentas distintas; si la API falla no hay respaldo local silencioso (H-19).
- HTTPS obligatorio en hosting; ninguna credencial en documentos ni pantallas.

3. Componentes de software

3.1 Vista de componentes

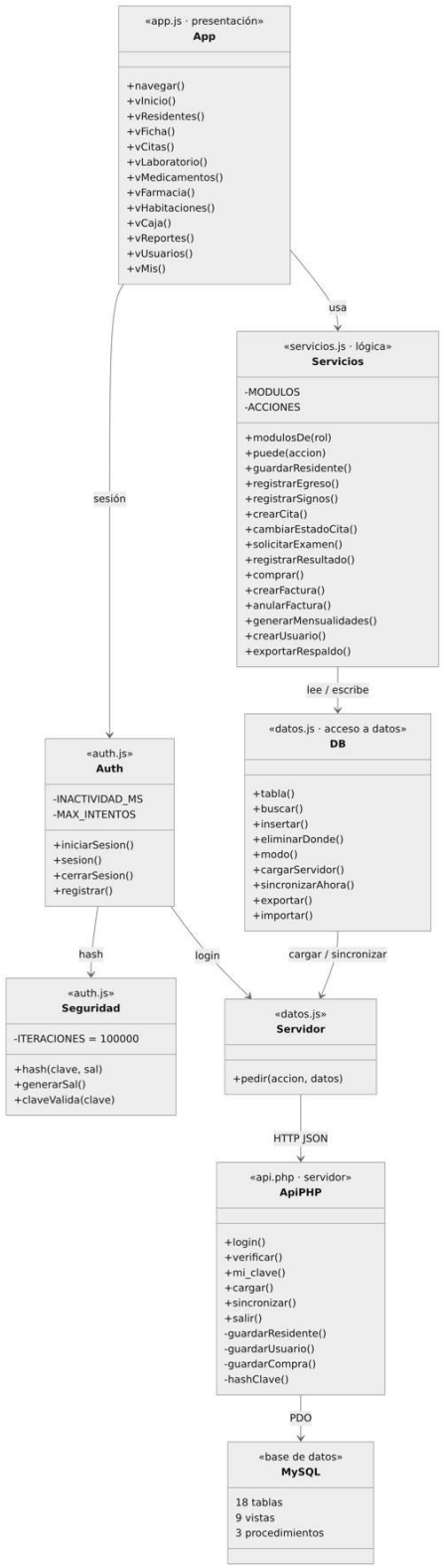


Figura 3. Componentes de software y sus dependencias

Componente	Archivo	Responsabilidad
App	js/app.js	Rutas #/módulo, menú agrupado por rol, 12 vistas, formularios, modales, avisos y notificaciones
Servicios	js/servicios.js	Reglas de negocio, validaciones, transiciones de estado y permisos (MODULOS y ACCIONES por rol)
Auth y Seguridad	js/auth.js	Inicio y cierre de sesión, inactividad, bloqueo, hash PBKDF2 y política de contraseña
DB y Servidor	js/datos.js	Datos en memoria, modo servidor o demostración, carga y sincronización con la API
API	api/api.php	Autenticación, permisos, validación de habitación, prohibición de borrar residentes, transacciones con PDO
Configuración	api/config.php	Datos de conexión a MySQL
Base de datos	basedatos/*.sql	Esquema, datos de prueba, vistas y procedimientos

3.2 Módulo de acceso y usuarios

El inicio de sesión sigue el diagrama DS-01: la página envía usuario y contraseña a la acción login; el servidor revisa el bloqueo, obtiene la sal y el hash, calcula hash_pbkdf2 y compara. Si la cuenta tiene **debe_cambiar_clave = 1**, responde que debe cambiarla y la página muestra «Crea tu contraseña personal». Solo después de cambiarla se permite la acción cargar.

3.3 Modelo de dominio

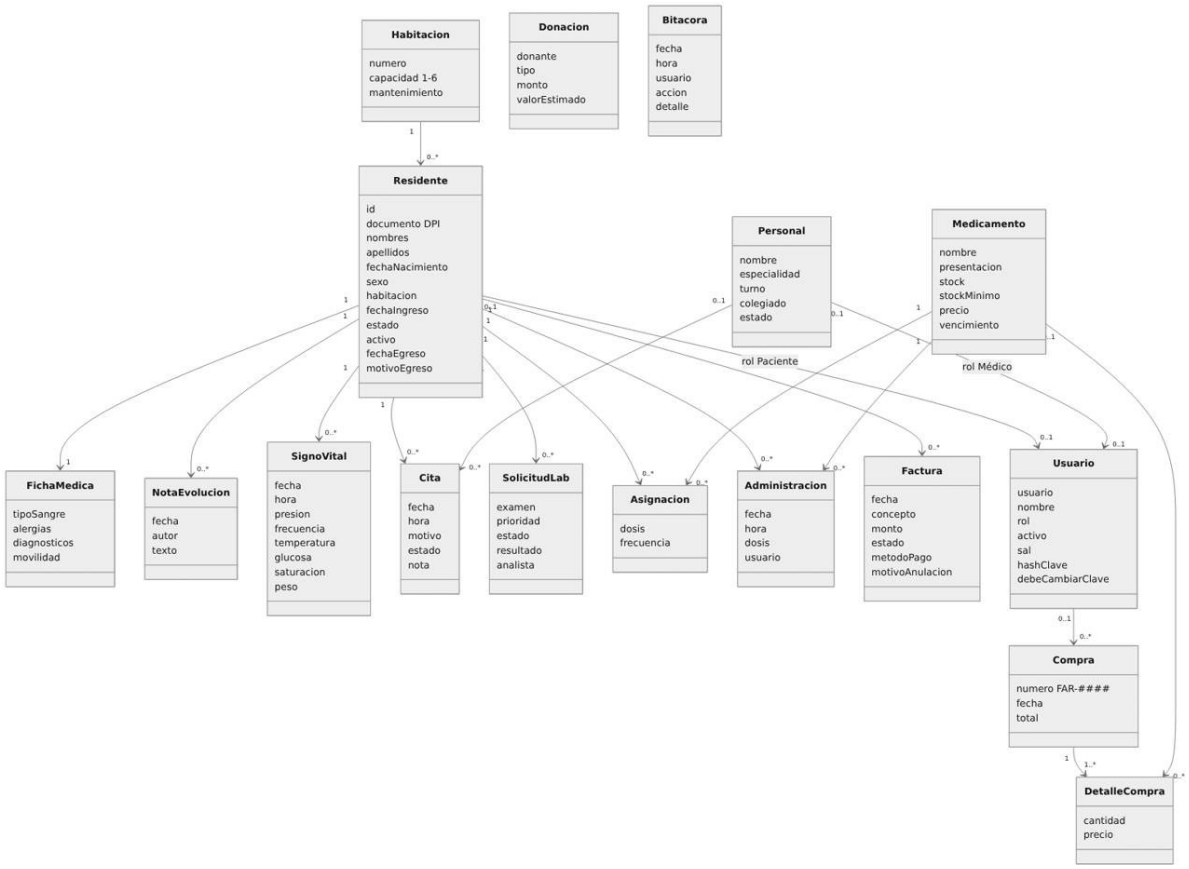


Figura 4. Modelo de dominio

3.4 Servicios y reglas de negocio

Servicio	Reglas que aplica
guardarResidente	RN-01 edad y DPI, RN-02 habitación, validación de fechas y teléfono
registrarEgreso	RN-03 baja lógica, RN-04 efectos del egreso
crearCita / cambiarEstadoCita / reprogramarCita	RN-05 horario y choques; transiciones Programada → Confirmada → En atención → Completada
solicitarExamen / iniciarExamen / registrarResultado	Prioridades y estados Pendiente → En proceso → Completado
comprar	RN-06 stock y vencimiento; recibo FAR-#### (RN-12)
crearFactura / pagarFactura / anularFactura / generarMensualidades	RN-07 y RN-08
crearUsuario / restablecerClave / cambiarMiClave	RN-09 y RN-11
exportarRespaldo / restaurarRespaldo	Respaldo JSON validado (RF-24)

4. Experiencia de usuario

4.1 Usuarios y contexto de uso

Rol	Contexto	Necesidad principal
Administrador	Oficina, computadora de escritorio	Ver el estado del asilo y registrar ingresos, cobros y usuarios rápidamente
Médico	Recorridos y consultorio, tableta o computadora	Ver la ficha completa, dar dosis y registrar signos sin perder tiempo
Laboratorio	Laboratorio, computadora	Ver la cola de solicitudes por prioridad y registrar resultados
Paciente	Teléfono o tableta	Consultar su información y comprar en la farmacia

4.2 Principios de diseño

1. **Cada rol ve solo su trabajo:** menú y panel según el rol (RNF-09).
2. **Legible para personal no técnico:** Inter para la interfaz y Fraunces para títulos, textos en español claro (RNF-02).
3. **Cualquier módulo en máximo 2 clics:** menú lateral agrupado en Principal, Atención, Administración y Sistema.
4. **El estado no depende solo del color:** cada insignia lleva texto (Estable, Pendiente, Vencido…).
5. **Prevención de errores:** validación al guardar con mensaje junto al campo; opciones no válidas deshabilitadas (habitaciones llenas).
6. **Respuesta inmediata:** avisos al terminar cada acción y notificaciones con lo pendiente.
7. **Funciona en teléfono:** desde 360 px, con barra inferior de navegación (RNF-03).

4.3 Arquitectura de información y navegación

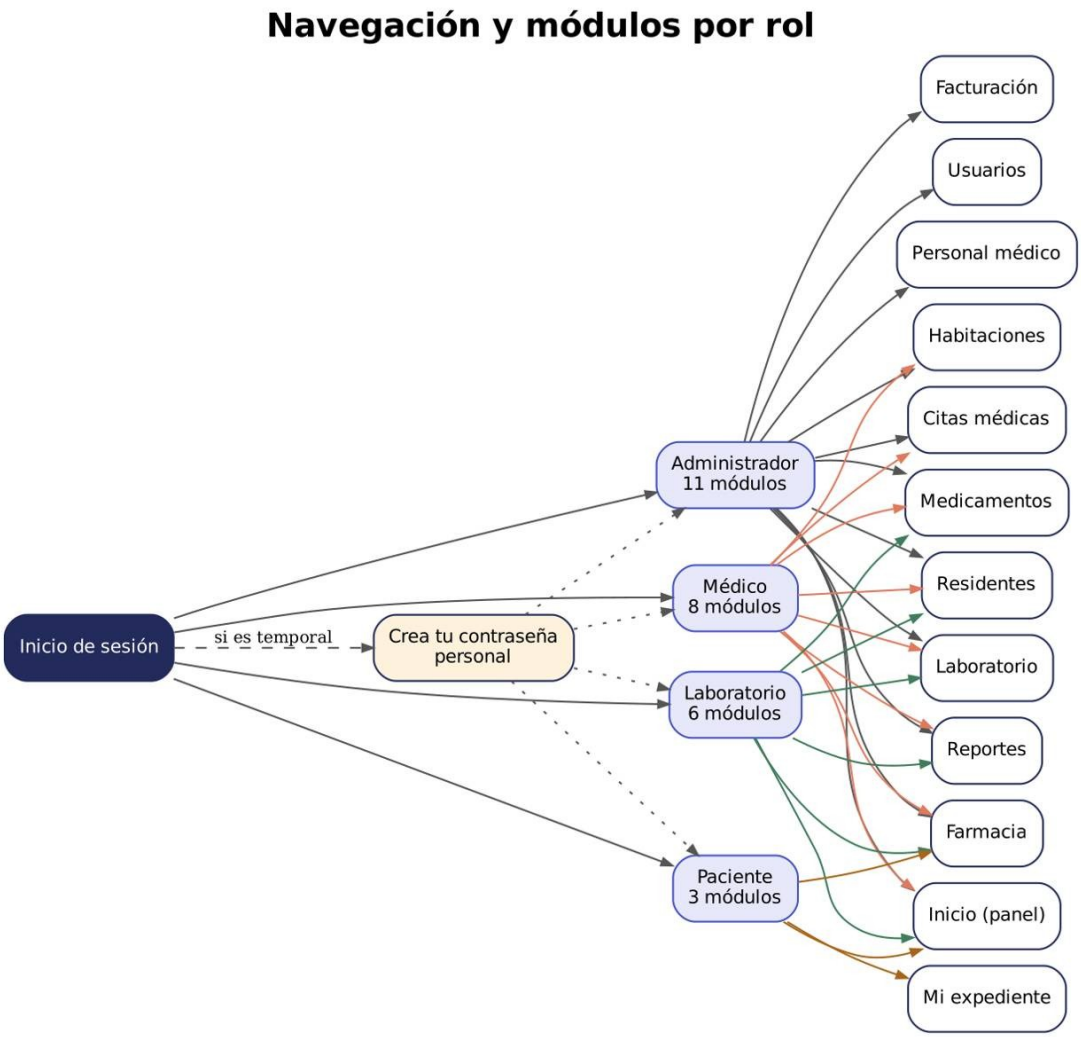


Figura 5. Navegación y módulos por rol

4.4 Patrones de interfaz

Patrón	Dónde se usa
Panel con accesos rápidos y tarjetas de indicadores	Inicio de cada rol
Tabla con buscador y filtros	Residentes, citas, personal, laboratorio, medicamentos, facturación
Ficha con encabezado del residente	Expediente: datos, ficha médica, signos, notas, medicamentos, citas y exámenes
Formulario en ventana modal	Altas y ediciones
Línea de tiempo	Agenda del día
Plano por tarjetas	Habitaciones y su ocupación
Carrito de compras	Farmacia del Paciente

Patrón	Dónde se usa
Vista previa + PDF/CSV	Reportes

4.5 Estados visibles

Las insignias usan cinco familias de color: **verde** (Estable, Completada, Pagada, Activo, Disponible), **ámbar** (En observación, Programada, Pendiente, Por vencer, Vacaciones), **azul** (Confirmada, En atención, En proceso, Ocupada), **rojo** (Delicado, Cancelada, Urgente, Vencido, Agotado) y **gris** (Egresado, Anulada, turnos). El detalle está en el Manual de Diseño Visual.

4.6 Patrones de diseño de software

Patrón	Aplicación
Módulo (IIFE de JavaScript)	Seguridad, Auth, DB, Servicios y App exponen solo sus funciones públicas
Fachada	Servicios ofrece operaciones de alto nivel (registrarEgreso) que coordinan varias tablas
Repositorio	DB centraliza el acceso a los datos, sea en memoria o en el servidor
Front controller	api/api.php recibe todas las peticiones y despacha por accion
Resultado uniforme	Cada servicio devuelve { ok, data } o { ok, error } para mostrar mensajes consistentes

5. Diseño detallado

Esta sección completa el diseño con lo que pidió la evaluación SQA por fases (H-11): especificación de la API, diseño de seguridad, diseño de pantallas e integridad de datos. Los diagramas de secuencia, estados y actividades están en la Fase de Análisis (figuras 4 a 15) y se actualizaron con estas decisiones.

5.1 Especificación de la API

Un único punto de entrada: **api/api.php?accion=<nombre>**. Peticiones GET (lectura) o POST con cuerpo JSON; respuestas JSON con **ok** (verdadero o falso) y, si falla, **error** con un mensaje en español. La sesión viaja en la cookie de PHP (same-origin); en hosting siempre por HTTPS.

Acción	Método y cuerpo	Respuesta correcta	Errores posibles
estado	GET	{ok, motor:"MySQL", sesion}	503 sin base de datos
publico	GET	{ok, residentes, personal, camasLibres}	503
login	POST {usuario, clave}	{ok, usuario:{id, nombre, rol, residenteId, personalId, cambiarClave}}	400 vacío · 401 incorrecto · 429 bloqueo de 30 s
verificar	POST {clave}	{ok}	401 sin sesión
mi_clave	POST {actual, nueva}	{ok}	400 actual incorrecta, nueva débil o igual
cargar	GET	{ok, datos:{config, tablas del rol…, seq}}	401 sin sesión · 403 contraseña temporal
sincronizar	POST {cambios:{tabla:{upsert:[…], delete:[ids]}}}	{ok}	403 permiso o registro ajeno · 422 regla de negocio · 500 base de datos
vaciar	POST {}	{ok}	403 si no es Administrador
salir	GET	{ok}	—

Reglas del servidor al sincronizar: todo ocurre en una transacción (si una fila falla se revierte todo); las bajas se aplican de hijos a padres y las altas de padres a hijos; los residentes nunca se borran (403); la bitácora es de solo agregar y el servidor fija el id, la fecha, la hora y el usuario; un registro con historial no se puede borrar (llaves RESTRICT → 422).

5.2 Diseño de seguridad

Se aplica **mínimo privilegio en el servidor**: la página oculta lo que el rol no usa, pero la protección real está en la API, porque una petición puede enviarse fuera de la página.

Rol	Qué recibe al cargar (lectura)	Qué puede modificar (escritura)
Administrador	Todo	Todo, excepto borrar residentes y la bitácora
Médico	Datos clínicos y operativos; sin facturas, donaciones ni compras; solo su cuenta y su bitácora	Residentes existentes (ficha, notas, signos, medicación) sin registrar ingresos ni egresos; citas; solicitudes de laboratorio; dosis

Rol	Qué recibe al cargar (lectura)	Qué puede modificar (escritura)
Laboratorio	Solicitudes de laboratorio; residentes solo con nombre, habitación, sangre y alergias; inventario	Solo solicitudes existentes (iniciar y registrar resultado); no crea solicitudes
Paciente	Solo su expediente, sus citas, exámenes, dosis, facturas y compras; catálogo de medicamentos; del personal solo nombre y especialidad	Compras nuevas a su nombre; solo descuenta existencias (nunca precio ni aumentos)

Amenaza	Control de diseño	Prueba
Robo de la base de contraseñas	PBKDF2-SHA256 600 000 iteraciones, sal de 16 bytes, formato con iteraciones y recálculo automático de hashes antiguos	PV-08, PV-09, CP-39, CP-40
Fuerza bruta en el inicio de sesión	Bloqueo de 30 s tras 3 fallos; hash calculado aunque el usuario no exista; registro en bitácora	PV-02, PV-03, PV-22
Acceso a datos de otro rol	Filtro por rol en la acción cargar	CP-28, CP-29, CP-30
Petición manipulada fuera de la página	Permisos por tabla y por registro en sincronizar	CP-31 a CP-34
Borrar o falsificar la auditoría	Bitácora de solo agregar con usuario y hora del servidor	CP-35
Pérdida de historial por borrados	Llaves foráneas ON DELETE RESTRICT y baja lógica	CP-36, CP-37, CP-38
Inyección SQL	Consultas preparadas de PDO en todas las entradas	CP-44
Código malicioso en textos (XSS)	Toda salida pasa por esc() antes de mostrarse	CP-44
Datos falsos por caída del servidor	Sin modo local silencioso; aviso de conexión; demostración solo explícita	CP-41, CP-42
Robo de sesión en tránsito	HTTPS obligatorio (redirección 301) y session_regenerate_id al entrar	PD-03

5.3 Diseño de pantallas (wireframes)

Bocetos de baja fidelidad hechos antes de la interfaz final; los números indican el orden de lectura. Las pantallas terminadas están en el Manual de Usuario y en la carpeta «Capturas del sistema».

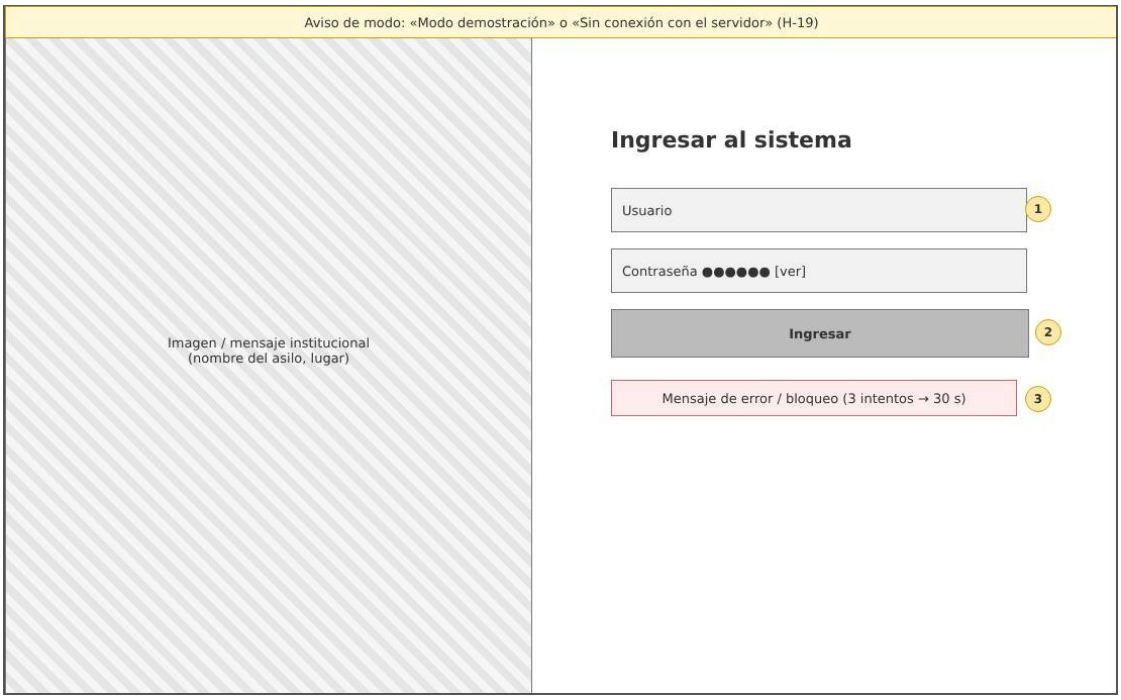


Figura 6. Inicio de sesión: usuario, contraseña, botón y mensaje de error o bloqueo

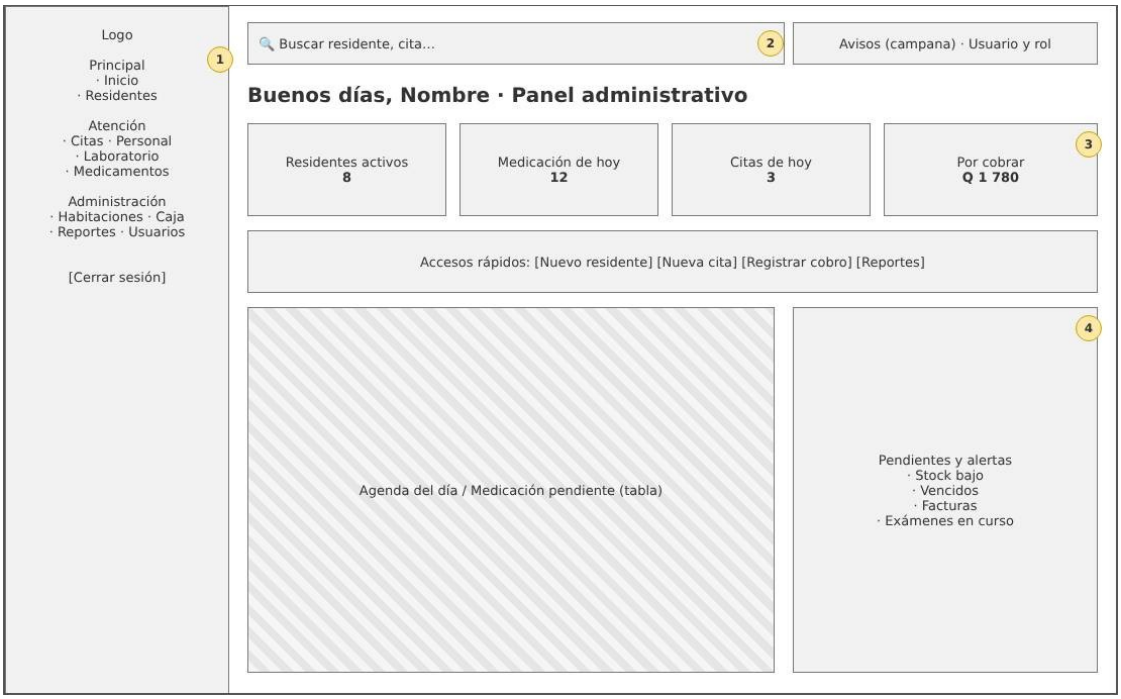


Figura 7. Panel del rol: menú lateral, buscador, indicadores, accesos y alertas

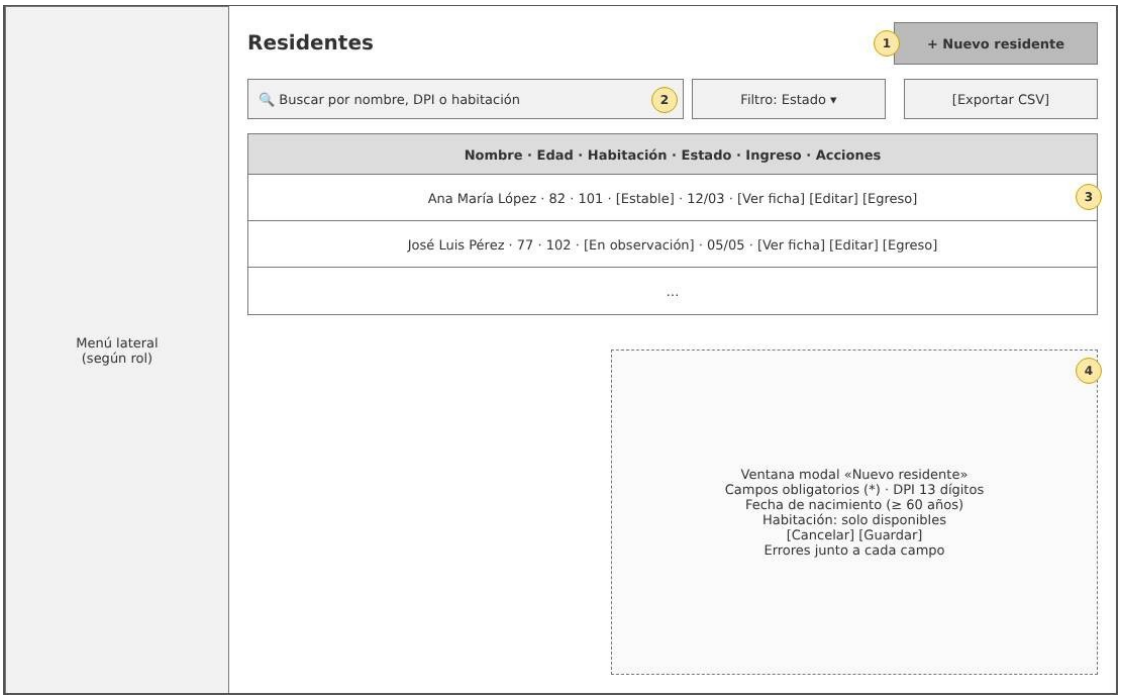


Figura 8. Listado con buscador, filtros, acciones por fila y ventana de registro



Figura 9. Ficha del residente: encabezado clínico, pestañas y notas de evolución



Figura 10. Vista de teléfono (360 px): tablas convertidas en tarjetas

5.4 Integridad de datos

- Todas las llaves foráneas usan **ON DELETE RESTRICT**: ningún borrado arrastra registros hijos (H-12). Las cuentas de usuario usan SET NULL para desvincularse sin borrarse.
- Los residentes y el personal con historial no se eliminan: se registra el egreso o se marca al profesional como «Inactivo».
- La solicitud de laboratorio tiene cuatro estados: Pendiente, En proceso, Completado y **Cancelado** (por egreso, H-13).
- Restricciones CHECK en capacidad, fechas, horarios, temperatura, saturación, stock y montos.
- Una base ya instalada se actualiza sin perder datos con 04_migracion_v2.sql (05_ en hosting).